

Marco integrativo GQM + PRAGMATIC para indicadores INES-ENS

Cómo conectar objetivos nacionales ENS-INES con métricas técnicas sin perderse en el camino.

1. Introducción

El Esquema Nacional de Seguridad (ENS) y el proyecto INES exigen algo más que rellenar informes: obligan a demostrar con métricas el estado de seguridad, la madurez y la resiliencia de las organizaciones públicas y de sus proveedores críticos.[web:8][web:37][web:39] Para asegurar que esas métricas no se conviertan en un mero ritual, este marco integra la metodología GQM (Goal-Question-Metric) con la evaluación PRAGMATIC (Predictivo, Relevante, Accionable, Genuino, Significativo, Preciso, Oportuno, Independiente, Rentable).

El objetivo es asegurar la trazabilidad desde los objetivos nacionales (ENS, RD 311/2022, guías CCN-STIC 815 y 824) hasta los datos técnicos que alimentan INES y los cuadros de mando internos.[web:20][web:33][web:37]

2. Recordatorio sucinto: GQM y PRAGMATIC

2.1. GQM (Goal-Question-Metric)

- Goal (Objetivo): qué se quiere lograr, en términos de seguridad y riesgo, desde la óptica ENS-INES.
- Question (Pregunta): qué debemos preguntarnos para saber si nos acercamos a ese objetivo.
- Metric (Métrica): qué medimos concretamente (dato) para responder a la pregunta.

GQM obliga a justificar cada métrica en función de una pregunta y un objetivo, y evita “coleccionar números” sin propósito.

2.2. PRAGMATIC

Cada métrica se evalúa cualitativamente según nueve criterios:

- P – Predictiva: ¿anticipa resultados futuros, no solo describe el pasado?
- R – Relevante: ¿importa realmente para los objetivos ENS-INES y de negocio?
- A – Accionable: ¿induce acciones claras cuando cambia su valor?
- G – Genuina: ¿refleja la realidad, sin ser fácilmente manipulable?
- M – Significativa (Meaningful): ¿es fácil de interpretar por sus destinatarios?
- P – Precisa: ¿es suficientemente exacta para el uso previsto?
- T – Oportuna (Timely): ¿se obtiene con la periodicidad adecuada?
- I – Independiente: ¿está lo bastante libre de sesgos y conflictos de interés?
- C – Rentable (Cost-effective): ¿su coste de obtención es proporcional al valor que aporta?

En este marco, cada métrica ENS-INES se acompaña de una mini-ficha GQM y de una calificación PRAGMATIC (Alta/Media/Baja) en cada criterio.

3. Dominios de indicadores ENS-INES cubiertos

El marco se aplica a siete dominios, coherentes con ENS, INES y las guías CCN-STIC:

1. Implantación de medidas ENS.
2. Eficacia y eficiencia de la seguridad.
3. Ciberincidentes y resiliencia.
4. Interconexiones, proveedores y cadena de suministro.
5. Madurez de gestión (modelo tipo CMM / IGM).
6. Uso de INES y herramientas (PILAR, LUCÍA, GRC).
7. Inversión y retorno (IGM, ROI, apetito de riesgo).
8. Riesgos emergentes (IA, post-cuántico, ciber crisis avanzada).

Para cada dominio se definen:

- Objetivos GQM de nivel nacional/organizativo.
- Preguntas GQM alineadas con ENS-INES.
- Métricas específicas, evaluadas con PRAGMATIC.

4. Ejemplo de plantilla GQM + PRAGMATIC por métrica

Se utilizará la siguiente ficha tipo:

- Goal:
- Question:
- Metric: definición, fuente, periodicidad.
- PRAGMATIC:
- Predictiva (Alta / Media / Baja) + breve justificación.
- Relevante (A/M/B).
- Accionable (A/M/B).
- Genuina (A/M/B).
- Significativa (A/M/B).
- Precisa (A/M/B).
- Oportuna (A/M/B).
- Independiente (A/M/B).
- Rentable (A/M/B).

5. Dominios y ejemplos GQM + PRAGMATIC

5.1. Implantación de medidas ENS

Goal 1: Asegurar que las medidas ENS aplicables están implantadas, documentadas y revisadas de forma sistemática en todos los sistemas bajo alcance.[web:20][web:33][web:37]

Question 1.1: ¿Qué porcentaje de medidas ENS aplicables están implantadas en cada sistema y globalmente en la organización?

- **Metric 1.1.1:** Porcentaje de medidas ENS implantadas sobre las aplicables.
- **Fuente:** inventario ENS, autoevaluaciones, auditorías (CCN-STIC 808, 802, 824).[web:18][web:38][web:33]
- **Periodicidad:** anual (al menos), preferible semestral.
- **PRAGMATIC:**
 - Predictiva:** Media (indica capacidad, no necesariamente eficacia).
 - Relevante:** Alta (núcleo de conformidad ENS).
 - Accionable:** Alta (identifica brechas por familia de medidas).
 - Genuina:** Media (riesgo de optimismo si no se audita).
 - Significativa:** Alta (fácil de interpretar).
 - Precisa:** Media (depende de calidad de inventario).
 - Oportuna:** Media (anual suele ser suficiente).
 - Independiente:** Media (mejor si la valida auditoría externa).
 - Rentable:** Alta (dato ya requerido para ENS/INES).
- **Predictiva:** Media (indica capacidad, no necesariamente eficacia).
- **Relevante:** Alta (núcleo de conformidad ENS).
- **Accionable:** Alta (identifica brechas por familia de medidas).
- **Genuina:** Media (riesgo de optimismo si no se audita).
- **Significativa:** Alta (fácil de interpretar).
- **Precisa:** Media (depende de calidad de inventario).
- **Oportuna:** Media (anual suele ser suficiente).
- **Independiente:** Media (mejor si la valida auditoría externa).
- **Rentable:** Alta (dato ya requerido para ENS/INES).

Question 1.2: ¿Con qué frecuencia se revisa el grado de implantación y se actualizan las evidencias?

- **Metric 1.2.1:** Frecuencia de revisión formal de implantación ENS (meses entre revisiones).
- **PRAGMATIC:** P: Media, R: Alta, A: Alta, G: Alta, M: Alta, P: Alta, T: Alta, I: Media, C: Alta.

Question 1.3: ¿Qué grado de automatización existe en la recopilación de datos sobre implantación?

- **Metric 1.3.1:** Porcentaje de medidas ENS cuya evidencia se obtiene de sistemas automatizados (GRC, CMDB, herramientas CCN).
- **PRAGMATIC:** P: Media, R: Media, A: Media, G: Alta, M: Media, P: Media, T: Alta, I: Alta, C: Media.

5.2. Eficacia y eficiencia de la seguridad

Goal 2: Evaluar si las medidas ENS implantadas reducen efectivamente incidentes y riesgos, y optimizar el uso de recursos dedicados a seguridad.[web:20][web:30][web:33]

Question 2.1: ¿Disminuyen los incidentes graves en el tiempo?

- Metric 2.1.1: Número de incidentes graves por año y por 1.000 activos críticos.
- Fuente: registro de incidentes (CCN-STIC 817, herramienta LUCÍA/SOC).[web:30][web:32]
- PRAGMATIC: P: Alta (tendencia), R: Alta, A: Alta, G: Alta (si se registran todos), M: Alta, P: Media, T: Media, I: Media, C: Media.

Question 2.2: ¿Mejora la capacidad de detección y respuesta?

- Metric 2.2.1: MTTD medio (Mean Time To Detect) para incidentes significativos.
- Metric 2.2.2: MTTR medio (Mean Time To Respond/Recover).
- PRAGMATIC (para ambas): P: Alta, R: Alta, A: Alta, G: Media, M: Alta, P: Media, T: Alta, I: Media, C: Media.

Question 2.3: ¿Es eficiente el esfuerzo invertido en seguridad?

- Metric 2.3.1: Porcentaje de presupuesto TIC dedicado a seguridad.
- Metric 2.3.2: Nº de FTE dedicados a seguridad por 1.000 usuarios.
- PRAGMATIC: P: Media, R: Alta, A: Media, G: Media, M: Alta, P: Alta, T: Media, I: Alta, C: Alta.

5.3. Ciberincidentes y resiliencia

Goal 3: Minimizar el impacto de ciberincidentes en servicios críticos y mejorar la resiliencia y la continuidad de negocio.[web:30][web:36][web:37]

Question 3.1: ¿Cuántos servicios críticos sufren interrupciones significativas por incidentes de seguridad?

- Metric 3.1.1: Nº de interrupciones de servicios críticos atribuibles a ciberincidentes (anual).
- PRAGMATIC: P: Alta, R: Alta, A: Alta, G: Media, M: Alta, P: Media, T: Media, I: Media, C: Media.

Question 3.2: ¿Se cumplen los objetivos de recuperación (RTO, RPO)?

- Metric 3.2.1: Porcentaje de incidentes en los que se cumple el RTO definido.
- PRAGMATIC: P: Alta, R: Alta, A: Alta, G: Media, M: Alta, P: Media, T: Alta, I: Media, C: Media.

Question 3.3: ¿Se gestionan sistemáticamente las causas raíz?

- Metric 3.3.1: Porcentaje de incidentes graves con análisis de causa raíz completado y acciones de mejora definidas.
- PRAGMATIC: P: Media, R: Alta, A: Alta, G: Alta, M: Alta, P: Alta, T: Media, I: Media, C: Alta.

5.4. Interconexiones, proveedores y cadena de suministro

Goal 4: Asegurar que las interconexiones y proveedores críticos cumplen requerimientos ENS/NIS2 y no introducen riesgos descontrolados.[web:35][web:21][web:24][web:27]

Question 4.1: ¿Qué proporción de proveedores críticos incluye cláusulas alineadas con ENS/NIS2?

- Metric 4.1.1: Porcentaje de contratos con proveedores críticos que incluyen cláusulas específicas de seguridad, notificación de incidentes y auditoría.[web:35]
- PRAGMATIC: P: Media, R: Alta, A: Alta, G: Alta, M: Alta, P: Alta, T: Media, I: Media, C: Alta.

Question 4.2: ¿Se evalúa regularmente la seguridad de proveedores?

- Metric 4.2.1: Porcentaje de proveedores críticos con evaluación de seguridad actualizada en los últimos 12 meses.
- PRAGMATIC: P: Media, R: Alta, A: Alta, G: Media, M: Alta, P: Media, T: Alta, I: Media, C: Media.

Question 4.3: ¿Se integran los proveedores en la gestión de incidentes y ciber crisis?

- Metric 4.3.1: Número de ejercicios o simulacros en los que han participado proveedores críticos en el último año.[web:36]
- PRAGMATIC: P: Media, R: Media, A: Alta, G: Alta, M: Media, P: Alta, T: Media, I: Alta, C: Media.

5.5. Madurez de gestión (IGM ENS-INES)

Goal 5: Mejorar de forma continua la madurez de gestión de la seguridad en dominios clave (riesgos, identidades, incidentes, continuidad, proveedores, cultura, métricas).[web:20][web:33]

Question 5.1: ¿Cuál es el nivel de madurez medio por dominio y global?

- Metric 5.1.1: Puntuación de madurez (1–5) por dominio.
- Metric 5.1.2: Índice Global de Madurez (IGM), media ponderada.
- PRAGMATIC: P: Alta (cuando se analiza en tendencia), R: Alta, A: Alta, G: Media, M: Alta, P: Media, T: Media, I: Media, C: Alta.

Question 5.2: ¿Mejora la madurez en el tiempo?

- Metric 5.2.1: Variación anual del IGM por dominio y global.
- PRAGMATIC: P: Alta, R: Alta, A: Alta, G: Alta, M: Alta, P: Media, T: Media, I: Alta, C: Alta.

5.6. Uso de INES y herramientas

Goal 6: Convertir INES y las herramientas asociadas en instrumentos de gestión y no solo de reporte.[web:8][web:33][web:39]

Question 6.1: ¿Se reciclan los datos de INES para la toma de decisiones interna?

- Metric 6.1.1: Indicador binario/ordinal de “grado de reutilización” de datos INES (por ejemplo, escala 1–4).
- PRAGMATIC: P: Media, R: Alta, A: Alta, G: Media, M: Media, P: Media, T: Alta, I: Media, C: Alta.

Question 6.2: ¿En qué medida se emplean herramientas del CCN (PILAR, LUCÍA) o GRC para soportar ENS?

- Metric 6.2.1: Porcentaje de procesos ENS soportados por herramientas específicas.
- PRAGMATIC: P: Media, R: Media, A: Media, G: Media, M: Media, P: Media, T: Media, I: Alta, C: Media.

5.7. Inversión, ROI y apetito de riesgo

Goal 7: Alinear la inversión en seguridad con el nivel de riesgo y maximizar el retorno (en términos de pérdidas evitadas y resiliencia).[web:20][web:33][web:35]

Question 7.1: ¿Es la inversión en seguridad coherente con el perfil de riesgo y con ENS/NIS2?

- Metric 7.1.1: % presupuesto TIC en seguridad comparado con sector y criticidad.
- PRAGMATIC: P: Media, R: Alta, A: Media, G: Media, M: Alta, P: Alta, T: Media, I: Alta, C: Alta.

Question 7.2: ¿Cuál es el ROI estimado de la seguridad?

- Metric 7.2.1: ROI básico = (beneficio estimado – gasto seguridad) / gasto seguridad, según plantilla Excel.
- PRAGMATIC: P: Alta (si se nutre de buenas estimaciones), R: Alta, A: Alta, G: Media, M: Media, P: Media, T: Media, I: Media, C: Media.

5.8. Riesgos emergentes (IA, post-cuántico, ciber crisis avanzada)

Goal 8: Preparar a la organización para amenazas emergentes (computación cuántica, IA, ataques avanzados) en coherencia con el principio de actualización permanente del ENS y las exigencias de NIS2.[web:37][web:21][web:24][web:27]

Question 8.1: ¿Se ha evaluado el impacto de la computación cuántica en la criptografía en uso?

- Metric 8.1.1: Estado de preparación post-cuántica (escala ordinal: no considerado / estudio / plan / ejecución).
- PRAGMATIC: P: Alta (a largo plazo), R: Media, A: Alta, G: Alta, M: Media, P: Media, T: Baja, I: Alta, C: Media.

Question 8.2: ¿Se gestionan riesgos asociados a IA (datos, modelos, decisiones)?

- Metric 8.2.1: N° de sistemas basados en IA con evaluación formal de riesgos de seguridad y privacidad completada.
- PRAGMATIC: P: Media, R: Alta, A: Alta, G: Media, M: Media, P: Media, T: Media, I: Media, C: Media.

6. Uso del marco en el ciclo ENS-INES

El marco GQM + PRAGMATIC se integra así en el ciclo anual:

9. Definir objetivos ENS–INES prioritarios para el ejercicio.
10. Seleccionar y/o ajustar las métricas GQM correspondientes.
11. Evaluar cada métrica con PRAGMATIC para priorizar las más útiles.
12. Recopilar datos (apoyándose en INES, auditorías, herramientas).
13. Analizar resultados, identificar brechas y acciones.
14. Revisar anualmente el set de métricas, eliminando las de bajo valor PRAGMATIC.

Si una métrica puntúa bajo en medio PRAGMATIC y nadie llora al eliminarla, probablemente nunca debió existir.